

Cisco Secure Workload - GDPR Compliance Report

Cisco Secure Workload - GDPR Compliance Report

Customer-Facing Compliance Report

Framework: EU General Data Protection Regulation 2016/679 (GDPR)

Primary audience: EU and EEA data controllers and processors and any organisation processing personal data of EU/EEA data subjects; DPO, privacy office, security, and application teams.

CSW positioning: Security of processing evidence (Article 32), data-flow inputs for the Record of Processing Activities (Article 30), breach timeline inputs (Articles 33-34), and processor-egress reconciliation (Article 28).

Framework Version Note

References GDPR as published (Regulation (EU) 2016/679). Article references in this report are well-known and stable. The UK GDPR (post-Brexit) is similar but separate; validate against the applicable text.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The technical runbook (CSW-GDPR-Technical-Runbook.md) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW “certifies” compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer’s compliance team, and the customer’s assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer’s governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

GDPR

- └ Personal-Data-Systems (Customer-Data-Stores, Application-Tier, Identity-Adjacent)
- └ Special-Category-Data-Systems (when applicable)
- └ Processors (Outsourced-Connectivity)
- └ Breach-Investigation

This scope pattern should be validated with the customer’s architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- Article 32 - Security of processing (segmentation, monitoring, vulnerability management)
- Article 30 - Records of processing (data-flow inputs only)
- Article 33 / 34 - Notification of breach (technical scoping inputs)
- Article 28 - Processor egress visibility

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- Article 6 / 9 - Lawful basis and special-category processing conditions
- Article 13-14 - Information to data subjects
- Article 15-22 - Data subject rights handling
- Article 35 - Data Protection Impact Assessment (CSW provides technical inputs only)
- Article 37-39 - DPO role and responsibilities
- International transfer mechanisms (Chapter V)

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
Article 32 - Security	Direct	Policy workspace +	Workspace snapshot

Framework topic	Coverage	CSW capability	Evidence artifact
of processing (segmentation)		ADM-derived allowlist	+ observed-vs-approved flow comparison
Article 32 - Security of processing (monitoring)	Direct	Continuous flow + process telemetry; alerts	Alert and anomaly log scoped to personal-data systems
Article 32 - Security of processing (encryption detection)	Supporting	Plaintext-flow detection on regulated paths	Detection input only
Article 30 - Records of processing	Supporting	Observed application data flows	Data-flow report by application owner (input to RoPA)
Article 28 - Processor egress	Supporting	Outbound flow summary to processor endpoints	Processor-egress report reconciled against processor register
Article 33 / 34 - Breach timeline	Supporting	Forensic flow + process telemetry	Investigation pack with timeline and data-subject-impact scoping inputs
Vulnerability handling	Direct	Reachability-weighted CVE on personal-data systems	Prioritised remediation list with compensating-control register

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Personal-data system inventory	Workloads with data_class=personal or special-category	Inventory + scope membership export	Monthly
Data-flow evidence (RoPA support)	Observed application data flows	ADM workspace export filtered by personal-data scope	Quarterly + on RoPA review
Segmentation evidence	Workspace snapshot + observed-vs-approved flow comparison	Policy workspace export + ADM export	Quarterly + after each change

Topic	What to collect	CSW source	Suggested cadence
Processor egress reconciliation	Outbound flow to processor endpoints	Flow search filtered to processor endpoints	Monthly
Vulnerability + reachability	CVE list weighted by reach into personal-data systems	Vulnerability report scoped to GDPR	Monthly
Breach timeline sample	Workload-level timeline for one representative incident	Flow + process search	Per breach; supports the 72-hour Article 33 timeline

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. `tenant`, `prototype`, `isa_level`, `npi`, `cui`, `ephi`).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not determine lawful basis or consent, conduct Data Protection Impact Assessments, fulfil data-subject rights requests, manage international transfer mechanisms, replace the DPO function, or make the Article 33 / 34 notification decisions.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.